



Citreia EIP-6780 Fix

Security Review

Cantina Managed review by:
Zigtur, Lead Security Researcher
N4nika, Associate Security Researcher

February 11, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
2.1	Scope	3
3	Overview	4
3.1	Executive Summary	4
3.2	Severity and Likelihood	4
3.3	Affected Versions	4
3.4	Affected Component and Root Cause	4
3.4.1	Root Cause	4
3.4.2	Supporting Context	4
3.5	Vulnerable Code (Exact Locations)	5
4	Findings	6
4.1	Informational	6
4.1.1	Lack of tests on EIP-7702 delegations executing SELFDESTRUCT opcode	6
4.1.2	Typographic issue in <code>db_commit.rs</code>	6

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Citrea is the first rollup that enhances the capabilities of Bitcoin blockspace with zero-knowledge technology, making it possible to build everything on Bitcoin.

From Feb 2nd to Feb 4th the Cantina team conducted a review of [citrea](#) on commit hash [\[PRIVATE\]](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	2	0
Total	2	2	0

2.1 Scope

The security review had the following components in scope for [citrea](#) on commit hash [\[PRIVATE\]](#):

```
├─ bin/citrea/src/guest.rs
├─ crates/evm/src
│   ├── call.rs
│   ├── evm
│   │   ├── db.rs
│   │   └─ db_commit.rs
│   ├── genesis.rs
│   ├── lib.rs
│   └─ query.rs
```

3 Overview

This security review is a fix review to a critical severity vulnerability found by Cantina autonomous bug hunter. The vulnerability has been fixed in commit 73aa41 which also contains the fixes highlighted in this report. This section describes this vulnerability

3.1 Executive Summary

Citrea's EVM state commit path skips writing selfdestructed accounts back to state. As a result, a contract balance that should be cleared on SELFDESTRUCT can remain intact in state. By prefunding a deterministic CREATE2 address, deploying a constructor that selfdestructs to a beneficiary, and redeploying the same CREATE2 contract, an attacker can repeatedly transfer the same balance to the beneficiary, effectively minting funds without reducing the original balance.

Impact: infinite minting of cBTC on L2, violating value conservation and enabling unbounded theft. If bridged or used as collateral, this can drain protocol funds and break accounting invariants.

3.2 Severity and Likelihood

- **Severity:** Critical
 - **Likelihood:** High
 - **Exploit cost:** Low (standard CREATE2 deployment and a few transactions)
 - **Privileges required:** None
 - **User interaction:** None
-

3.3 Affected Versions

- Mainnet reports citrea/v1.0.2 via web3_clientVersion (see verification below).
 - The vulnerable code is present in tag v1.0.2 at commit 75d514fb1f27e106d3e54ae329960d37e2f853fb.
-

3.4 Affected Component and Root Cause

3.4.1 Root Cause

In `crates/evm/src/evm/db_commit.rs`, selfdestructed accounts are skipped during state commit:

```
if account.is_selfdestructed() {  
    continue;  
}
```

This prevents the account's updated balance (zero) and deletion markers from being persisted. The pre-existing balance remains in the state database, even though the beneficiary has already received the transfer.

3.4.2 Supporting Context

`crates/evm/src/evm/handler.rs` also documents that certain selfdestruct flows intentionally keep the balance unchanged for Cancun semantics, but the commit path currently skips all selfdestructed accounts regardless of intended semantics. In the PoC, the contract is created and selfdestructs in the same transaction, so the balance should be zeroed and the account deleted.

3.5 Vulnerable Code (Exact Locations)

From the current repository (tag v1.0.2, commit 75d514fb1f27e106d3e54ae329960d37e2f853fb):

crates/evm/src/evm/db_commit.rs:23-25

```
if account.is_selfdestructed() {  
    continue;  
}
```

crates/evm/src/evm/handler.rs:717-721

```
// State is not changed:  
// * if we are after Cancun upgrade and  
// * Selfdestruct account that is created in the same transaction and  
// * Specify the target is same as selfdestructed account. The balance stays unchanged.
```

4 Findings

4.1 Informational

4.1.1 Lack of tests on EIP-7702 delegations executing SELFDESTRUCT opcode

Severity: Informational

Context: `db_commit.rs#L22`

Description: The tests added in `crates/evm/src/tests/call_tests.rs` do not ensure that the SELFDESTRUCT opcode has the expected behavior with EIP-7702 delegations.

Note: In revm context, the `is_selfdestructed()` flag is only true when `is_created()` was true (for post-Cancun), which only happens for contracts created via CREATE/CREATE2, not for EIP-7702 delegations. This should not have any impact..

Recommendation: Implement tests to ensure that an EOA with an EIP-7702 delegation has the expected behavior when executing the SELFDESTRUCT opcode.

Citrea: Fixed in commit [73aa141](#).

Cantina: Fixed.

4.1.2 Typographic issue in `db_commit.rs`

Severity: Informational

Context: `db_commit.rs#L26`

Description: A comment in `db_commit.rs` indicates the following.

Any cBTC in the contract before selfdestruct is send to some beneficiary.

Recommendation: Fix the comment to the following.

Any cBTC in the contract before selfdestruct is sent to some beneficiary.

Citrea: Fixed in commit [73aa141](#).

Cantina: Fixed.